DOSSIER E5 - SÉCURITÉ PÉRIMÉTRIQUE

Accès Distant Sécurisé avec pfSense & OpenVPN

Implémentation d'un tunnel VPN SSL pour télétravailleurs

Candidat : Younes Bouizergane

Authentification
Certificats X.509

Confidentialité
Chiffrement AES-256

Contexte : TechSolutions Consulting

L'Organisation

Cabinet de conseil IT basé à Paris avec 30 consultants souvent en déplacement.

- **Siège :** Serveur de fichiers, CRM Interne, AD.
- **Utilisateurs :** Consultants nomades (Hôtels, 4G, Domicile).

Risques Actuels

Actuellement, les consultants utilisent TeamViewer ou exposent des ports RDP (3389) directement sur Internet.
Risque critique de ransomware et d'intrusion.

◎ Objectifs du Projet

Tunnel Sécurisé

Créer un canal chiffré (VPN) encapsulant tout le trafic professionnel à travers Internet.

Authentification Forte

Utiliser une double authentification : Certificat Machine + Login/Mot de passe utilisateur.

Filtrage Granulaire

Restreindre l'accès uniquement aux serveurs nécessaires (Pas d'accès total au LAN).

Facilité de Déploiement

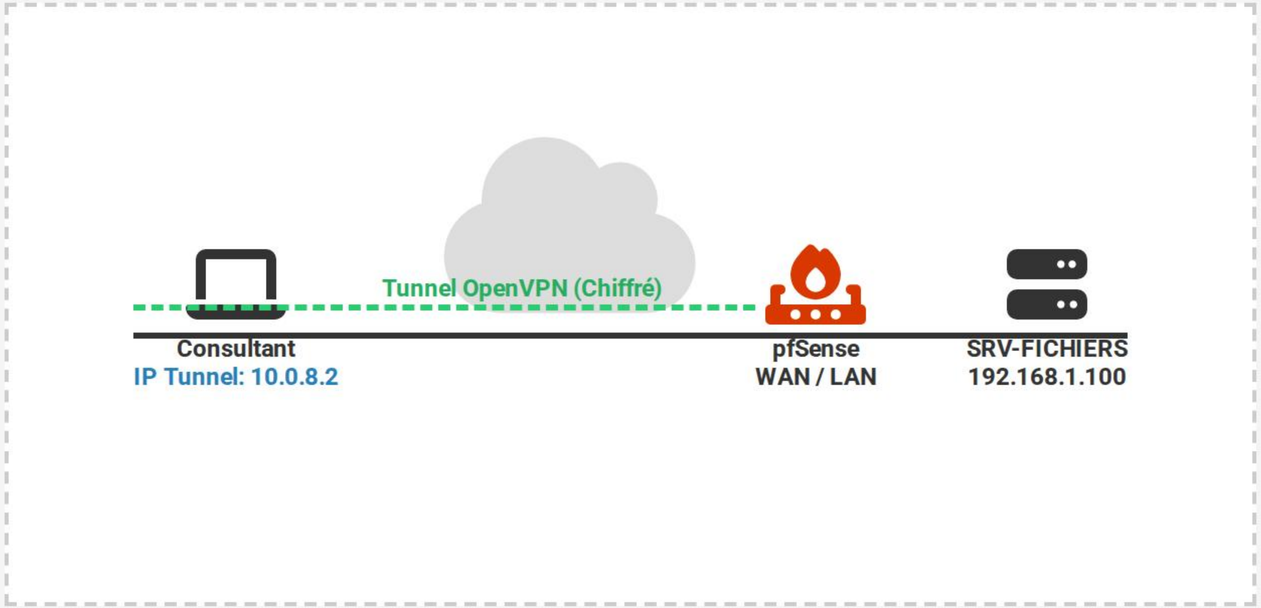
Fournir un exécutable "clé en main" pour les consultants non-techniciens.

Architecture VPN SSL (OpenVPN)

OpenVPN utilise le protocole SSL/TLS (comme le HTTPS) pour établir le tunnel.

Flux de connexion :

1. Le client contacte l'IP Publique du pfSense (WAN) sur le port UDP 1194.
2. Authentification TLS (Échange de clés).
3. Création de l'interface virtuelle (TUN).
4. Le client obtient une IP dans le réseau tunnel `10.0.8.0/24`.



Choix Technologiques

pfSense

Pare-feu Stateful Open Source basé sur FreeBSD. Très robuste, il inclut nativement OpenVPN sans coût de licence (contrairement à Cisco/Fortinet).

OpenVPN (SSL)

Plus flexible qu'IPsec pour les clients nomades. Passe facilement à travers les pare-feux des hôtels/Wi-Fi publics (utilise un seul port UDP/TCP).

Cryptographie

Utilisation de **AES-256-GCM** (Hardware accelerated) pour un chiffrement inviolable et performant.

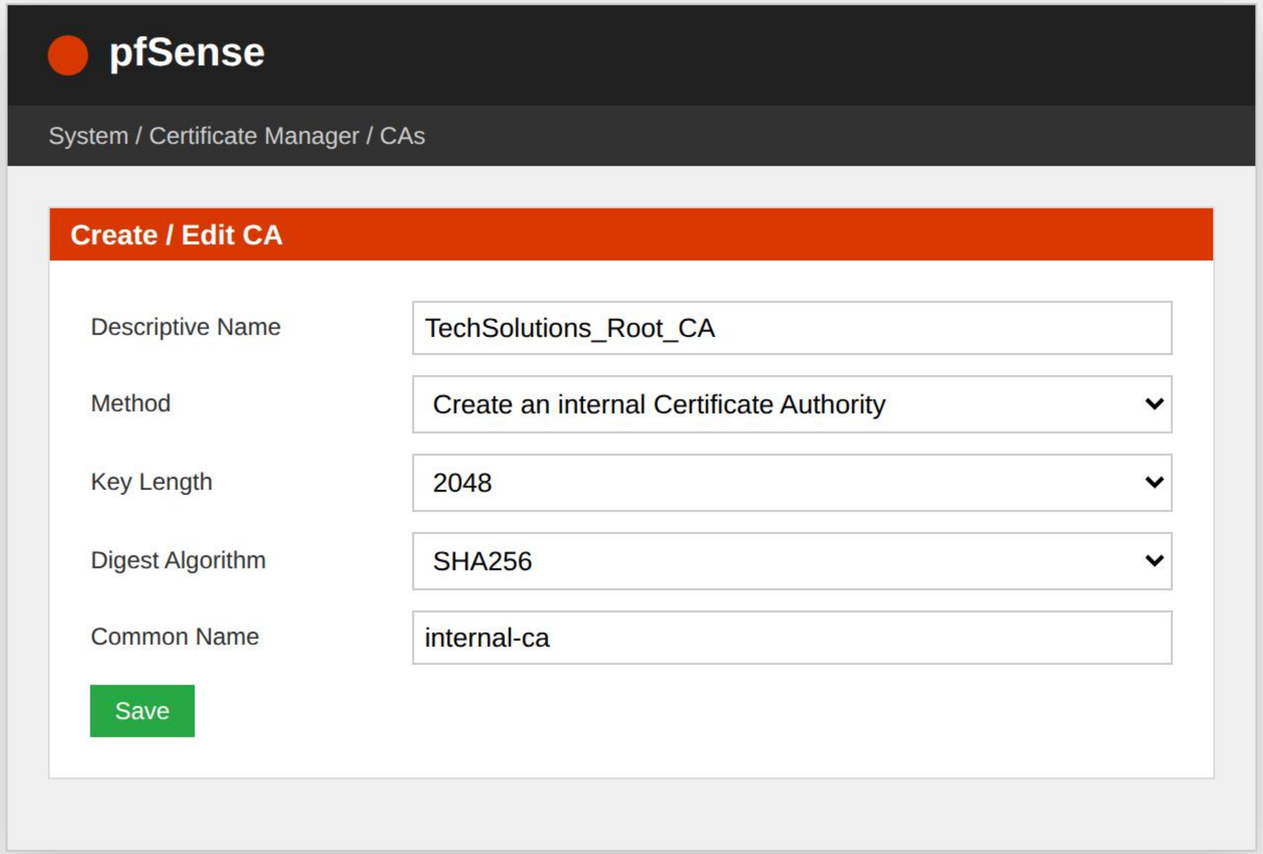
PKI Intégrée

pfSense intègre un gestionnaire de certificats complet (CA, Certs Serveur, Certs Utilisateurs), simplifiant la gestion de la confiance.

Étape 1 : Création de la PKI (CA)

Avant de créer le VPN, nous devons établir une chaîne de confiance.

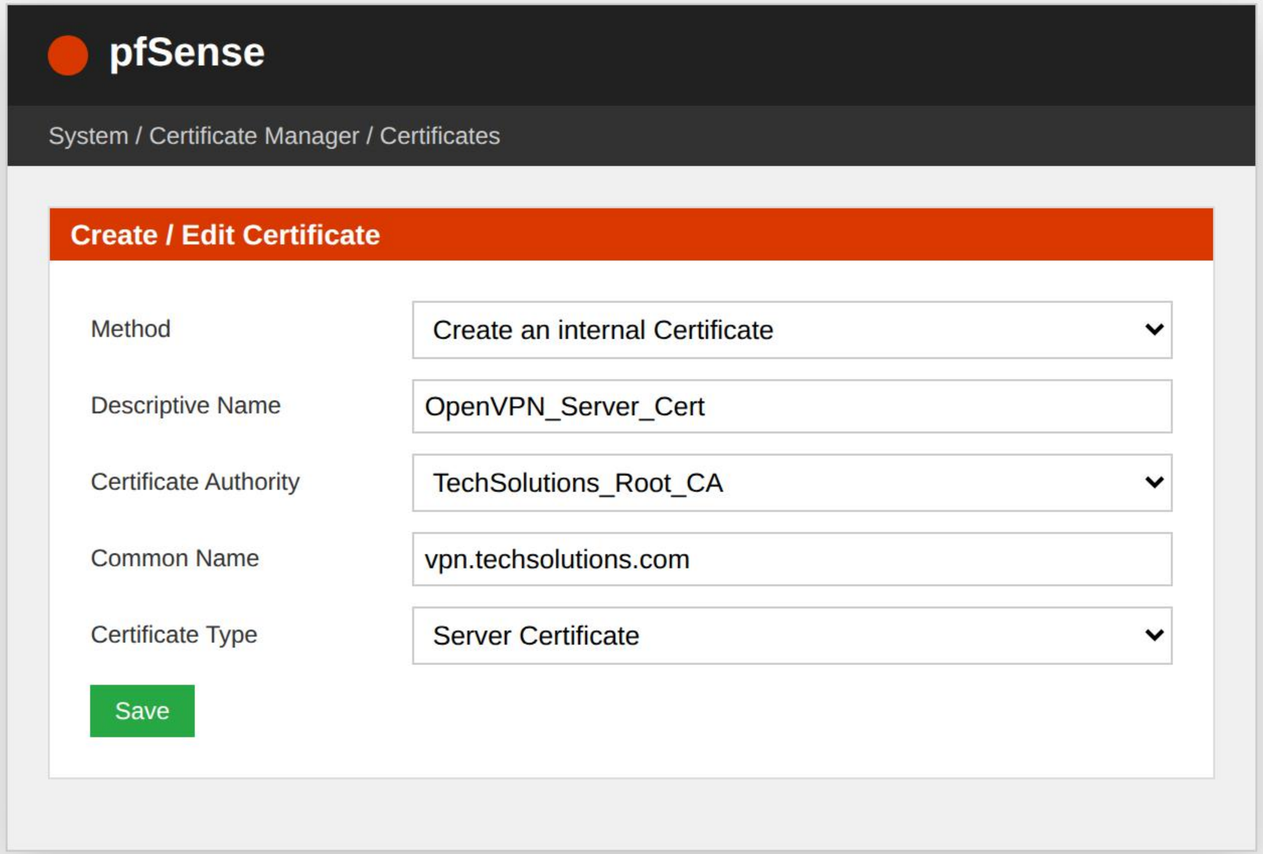
Nous créons une **Autorité de Certification (CA)** interne sur pfSense. Elle servira à signer les certificats du serveur VPN et des utilisateurs.



Étape 2 : Certificat Serveur

Le serveur OpenVPN a besoin de son propre certificat pour prouver son identité aux clients (éviter les "Man-in-the-Middle").

Ce certificat est signé par notre CA interne créée à l'étape précédente.

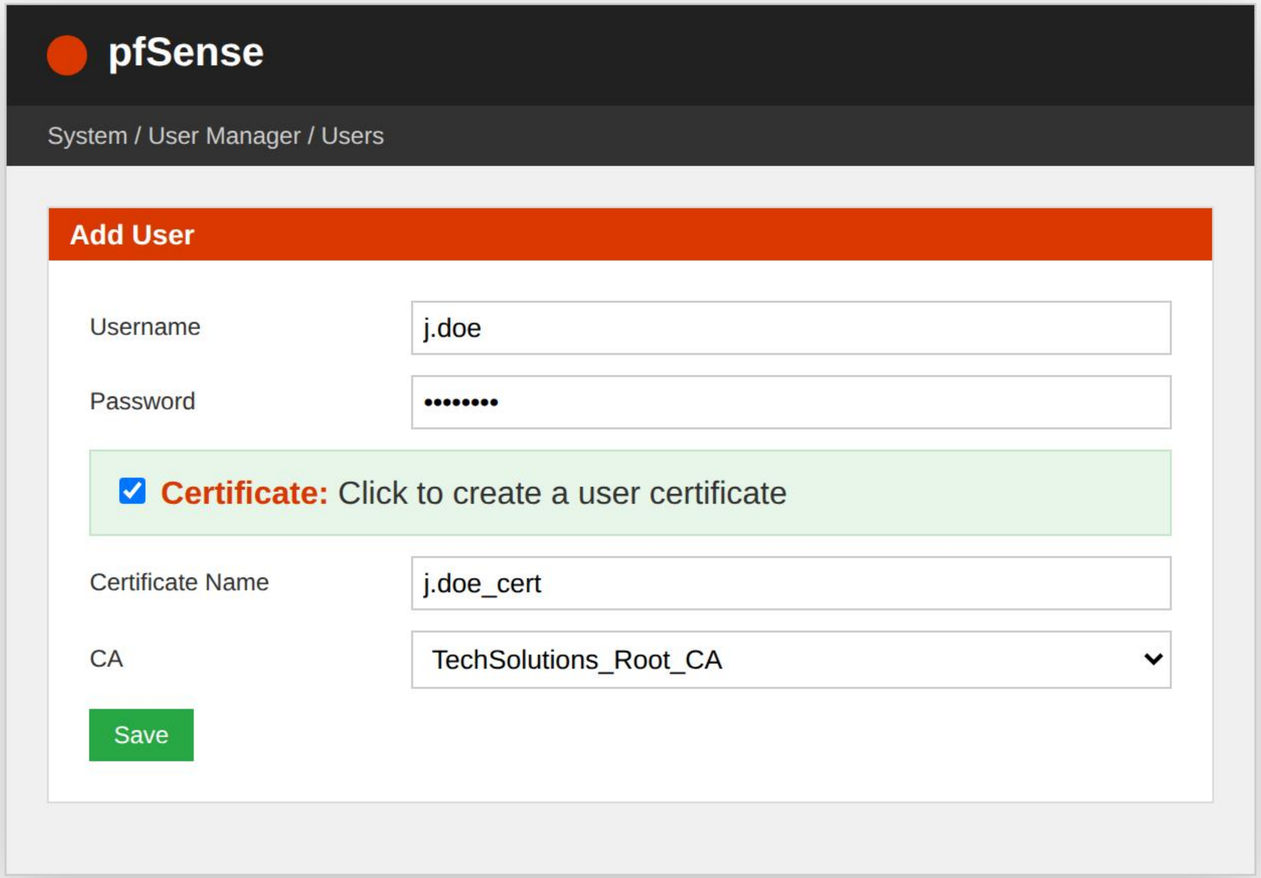


Étape 3 : Création Utilisateur

Création d'un compte utilisateur pour un consultant.

Important : Nous cochons la case "Click to create a user certificate".

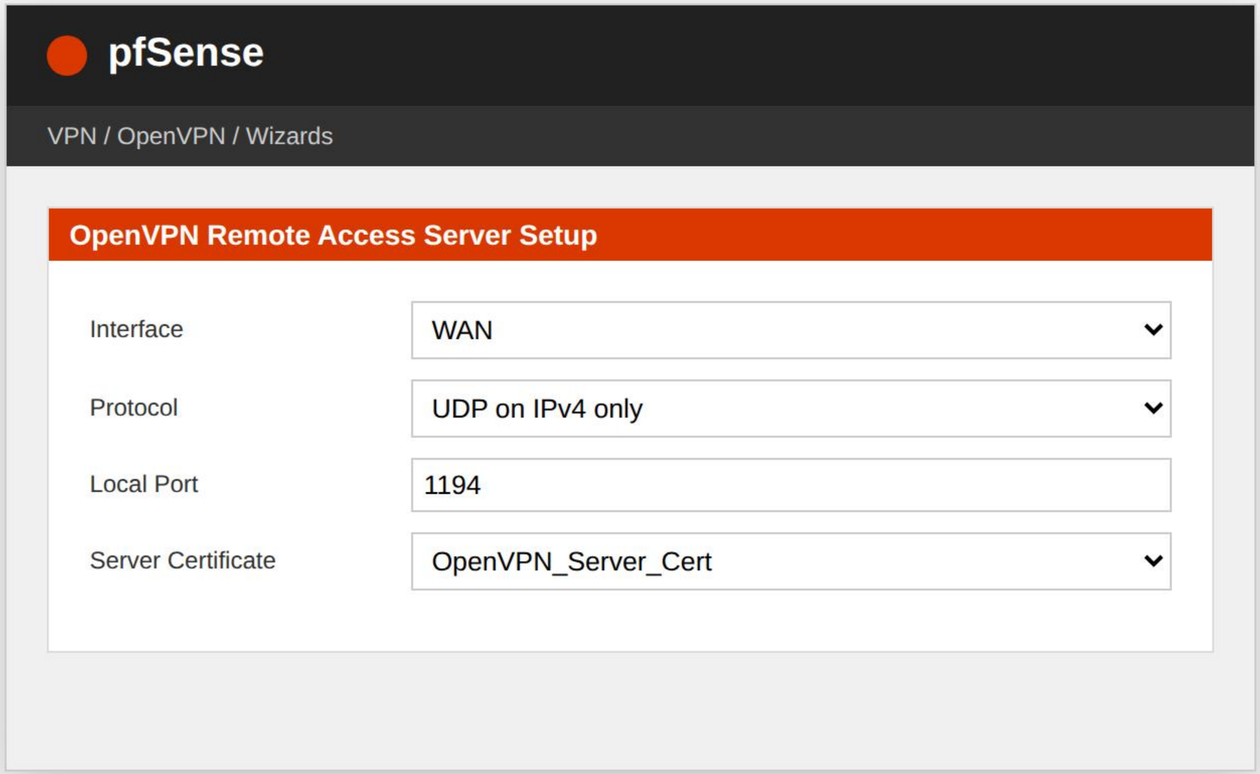
Cela génère automatiquement un certificat client personnel, indispensable pour l'authentification mutuelle.



🪄 Étape 4 : OpenVPN Wizard

Utilisation de l'assistant pour configurer le serveur.

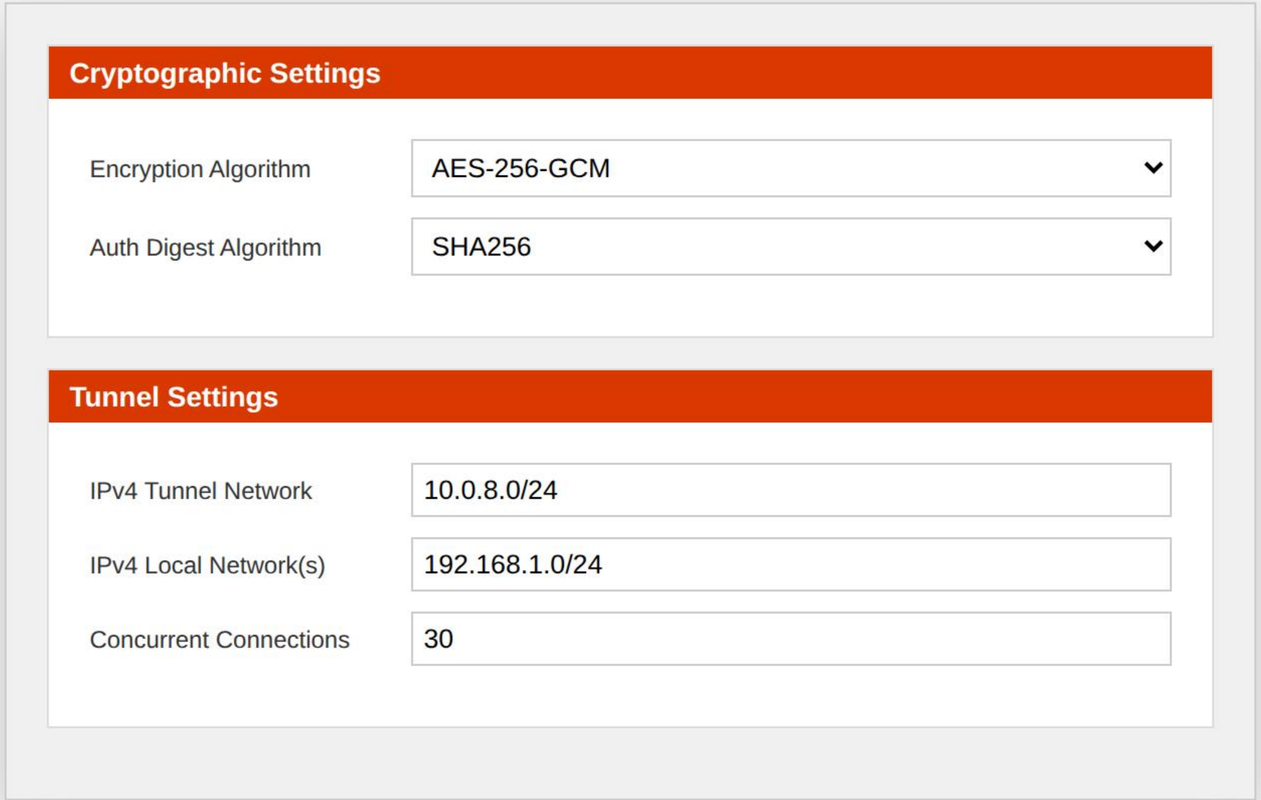
- **Interface :** WAN (L'écoute se fait sur l'IP publique).
- **Protocole :** UDP (Plus rapide que TCP pour le VPN).
- **Port :** 1194 (Standard).
- **Description :** Remote Access VPN.



Étape 5 : Réseau Tunnel

Configuration de l'adressage IP virtuel.

- **Cryptographic Settings :** AES-256-GCM (Top sécurité).
- **Tunnel Network :** `10.0.8.0/24`. C'est le réseau virtuel. Les clients auront des IP comme 10.0.8.2, 10.0.8.3, etc.
- **Local Network :** `192.168.1.0/24`. C'est le réseau LAN de l'entreprise auquel on veut accéder.



Étape 6 : Règles Firewall (WAN)

Pour que le VPN fonctionne, il faut autoriser les connexions entrantes sur l'interface WAN.

Règle : Autoriser le trafic UDP sur le port 1194 venant de n'importe où (Source: Any).

Firewall / Rules / WAN

Proto	Source	Port	Destination	Port	Action
IPv4 UDP	*	*	WAN Address	1194	✓ Pass
IPv4 *	*	*	*	*	✕ Block

Étape 7 : Règles Firewall (OpenVPN)

Une fois dans le tunnel, qu'est-ce que le client a le droit de faire ?

On crée une règle sur l'interface virtuelle "OpenVPN" pour autoriser l'accès au LAN.

Note : On peut être plus restrictif ici et n'autoriser que l'accès au serveur de fichiers.

Firewall / Rules / OpenVPN

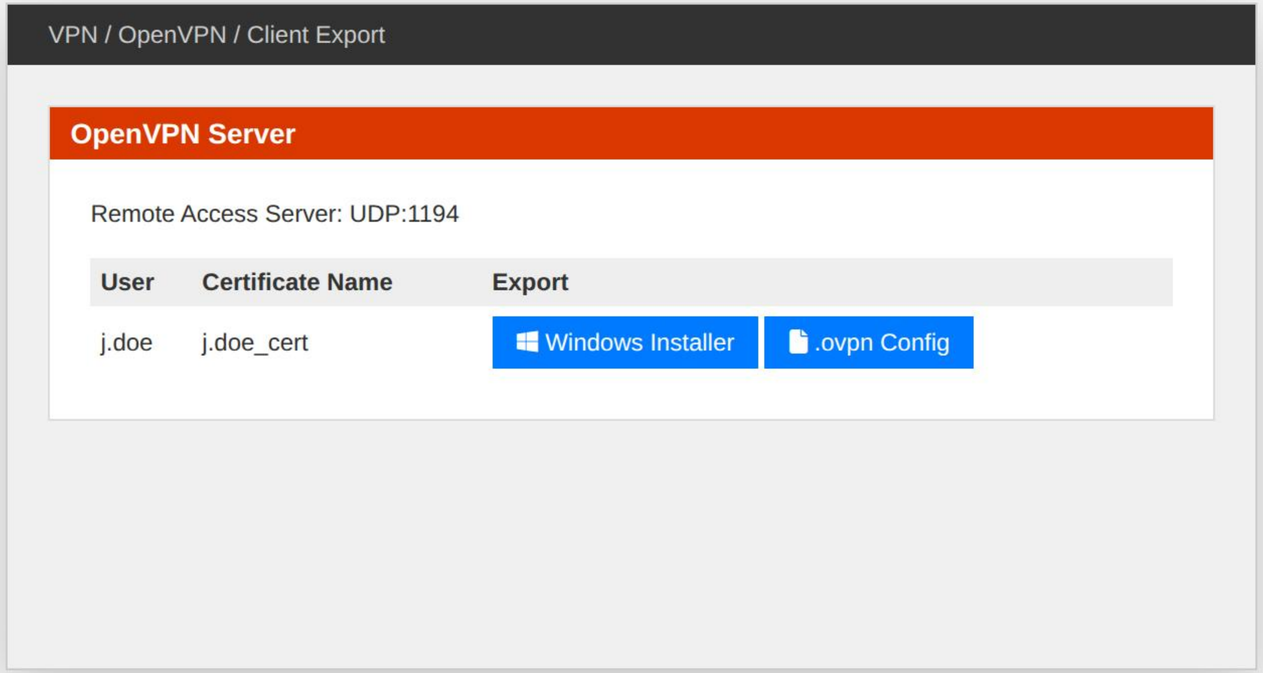
Proto	Source	Destination	Action
IPv4 *	Network (10.0.8.0/24)	LAN net	✓ Pass

Étape 8 : Package Client Export

Le package **OpenVPN Client Export** (à installer via le gestionnaire de paquets) simplifie tout.

Il génère un fichier `.ovpn` ou un installateur `.exe` qui contient déjà :

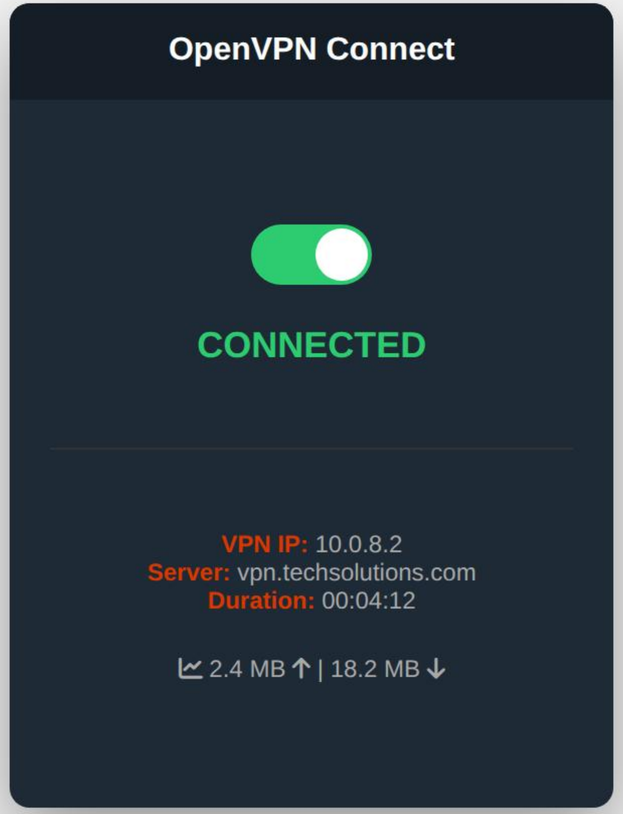
- La configuration IP.
- Le certificat CA.
- Le certificat de l'utilisateur.
- La clé privée.



Le Côté Client

Sur le PC du consultant :

1. Installation du client OpenVPN Connect.
2. Importation du fichier de profil fourni.
3. Connexion avec Login / Mot de passe.

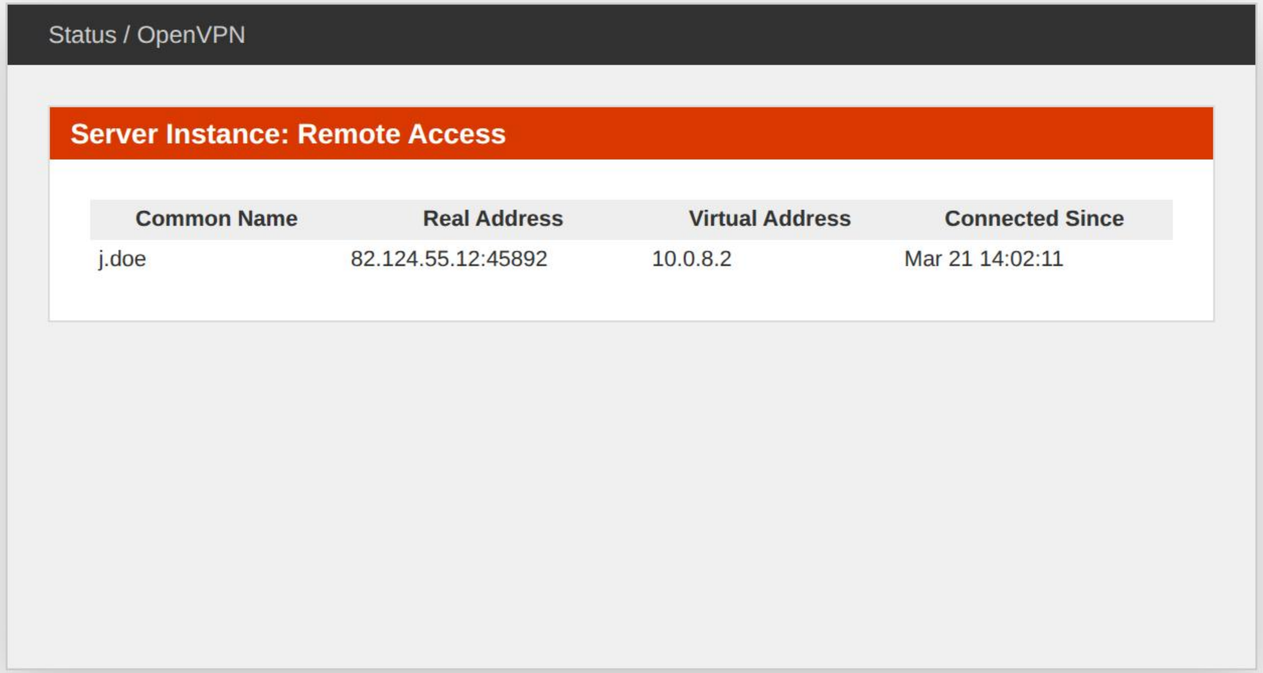


Logs & Supervision

Vérification des connexions actives côté pfSense.

Les logs permettent de voir :

- L'IP publique du client.
- L'heure de connexion.
- L'IP virtuelle attribuée (10.0.8.x).
- Les erreurs d'authentification.



Validation Technique

Test depuis le PC du consultant connecté en 4G.

Le Ping vers le serveur de fichiers interne (192.168.1.100) doit fonctionner à travers le tunnel.

```
C:\Users\j.doe> ipconfig /all

Carte Ethernet OpenVPN TAP-Windows6 :
  Adresse IPv4. . . . . . . . . .: 10.0.8.2
  Masque de sous-réseau. . . . : 255.255.255.0

C:\Users\j.doe> ping 192.168.1.100

Envoi d'une requête 'Ping' 192.168.1.100 avec 32 octets de données :
Réponse de 192.168.1.100 : octets=32 temps=24 ms TTL=127
Réponse de 192.168.1.100 : octets=32 temps=21 ms TTL=127
Réponse de 192.168.1.100 : octets=32 temps=28 ms TTL=127

Statistiques Ping :
  Paquets : envoyés = 3, reçus = 3, perdus = 0 (perte 0%),
```

Pour aller plus loin (Sécurité)

MFA / OTP

Ajouter une couche de sécurité avec Google Authenticator (via le package `openvpn-client-export` et FreeRADIUS) pour exiger un code temporaire.

Révocation (CRL)

Si un PC portable est volé, il faut immédiatement révoquer son certificat dans pfSense pour bloquer l'accès, même si le mot de passe est connu.

TLS-Auth (HMAC)

Activer la clé statique TLS (Ta.key) pour protéger le serveur contre les attaques DoS et scanner de ports (le paquet est jeté si la signature HMAC est invalide).

Filtrage IP

Si possible, restreindre l'accès au port 1194 uniquement aux IP françaises via **pfBlockerNG** (GeoIP Blocking).

🏁 Conclusion

Bilan du Projet

- ✅ Accès sécurisé et chiffré pour tous les nomades.
- ✅ Authentification forte (Certificat + MDP).
- ✅ Fermeture des ports RDP exposés (Réduction drastique de la surface d'attaque).

MISSION ACCOMPLIE